# Metodología forense integrada: del encargo al informe

## Del laboratorio aislado al caso completo

Hasta ahora cada lección trabajó una pieza: adquirir una copia y verificarla, preservar fuentes, construir una línea de tiempo de sistema operativo, analizar tráfico de red, correlacionar una base de datos y combinar fuentes cloud y móviles. En un caso real esas piezas no llegan ordenadas. Llega una persona preocupada, con una petición amplia, poco tiempo y, muchas veces, una sospecha ya formada.

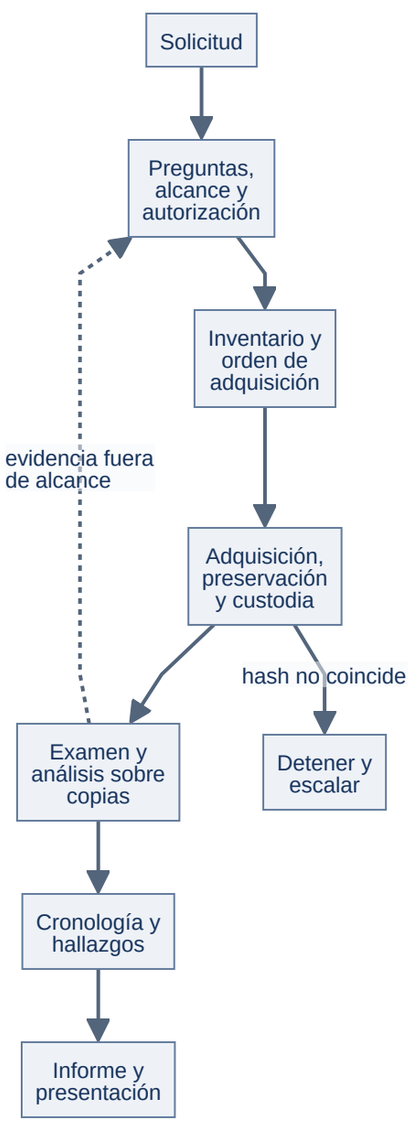
La pregunta de esta lección es:

> ¿Cómo se convierte una solicitud ambigua en un trabajo forense que otra persona pueda revisar, repetir y defender?

Cuatro ideas ordenan la lección:

1. **la solicitud no es la pregunta**: la petición de gerencia se transforma en preguntas forenses acotadas antes de tocar la evidencia;
2. **la autorización es el límite**: lo que no está autorizado se escala, no se "revisa por si acaso";
3. **la custodia es continua**: cada entrega, copia y cambio de estado queda registrado, sin huecos ni datos inventados;
4. **el hallazgo es reproducible o no es hallazgo**: cada afirmación del informe se puede rastrear hasta una evidencia, un procedimiento y una salida guardada.

El trabajo completo sigue una secuencia en la que cada etapa deja un producto que la siguiente necesita:




La flecha punteada es tan importante como las continuas: cuando aparece algo que el plan no contemplaba, no se improvisa. Se vuelve al alcance y se decide con quien autorizó.

## 1. La solicitud no es la pregunta

Una solicitud de gerencia expresa una preocupación de negocio. Suele incluir supuestos ("fue tal persona"), verbos amplios ("revisar todo"), plazos ("en 24 horas") y fuentes que nadie ha autorizado ("su teléfono"). El primer trabajo del equipo forense es separar esas capas.

| Lo que dice la solicitud | Problema | Cómo se transforma |
|---|---|---|
| "Revisen todo su correo del último año" | Alcance desproporcionado y no verificable | Fuentes concretas, intervalo y objetivo |
| "Sospecho de la vendedora" | Presupone el resultado; sesgo de confirmación | Preguntar por cuentas, sesiones y equipos, no por culpables |
| "Revisen también su celular" | Fuente personal; autoridad dudosa | Excluir o escalar a quien autoriza |
| "Préndanlo y vean qué tiene" | Decisión técnica tomada por quien no es especialista; encender o apagar altera el estado | Evaluar estado, volatilidad y método antes de actuar |
| "Lo necesito para mañana" | El plazo no define qué se entrega | Acordar un primer informe parcial con límites declarados |
| "Quiero saber si nos traicionó" | Pregunta sobre intención de una persona; la evidencia técnica rara vez la demuestra | Responder sobre cuentas, equipos y acciones; declarar la brecha de atribución |

### Qué hace forense a una pregunta

Una pregunta forense:

- se responde con evidencia que existe o puede obtenerse;
- tiene un **objeto** (qué información, qué cuenta, qué equipo) y un **intervalo**;
- no presupone el resultado;
- permite decir "sí", "no" o "no puede determinarse con estas fuentes".

| Pregunta débil | Pregunta forense |
|---|---|
| ¿La vendedora vendió los precios? | ¿Salió de la organización, mediante recursos corporativos, la lista de precios 2027 entre el 01-09 y el 07-09? |
| ¿Qué hizo con su computador? | ¿Qué registros del equipo `CA-NB-04` muestran acceso al archivo de precios en ese intervalo? |
| ¿A quién se lo mandó? | ¿Qué destinatarios externos recibieron, desde la cuenta corporativa, mensajes con ese archivo en ese intervalo? |

Las preguntas se **priorizan**: primero las que dependen de fuentes que se pueden perder y las que responden directamente al objetivo autorizado.

## 2. Autorización, alcance y proporcionalidad

Antes de adquirir cualquier fuente se necesita saber **quién autoriza**, **qué autoriza** y **hasta dónde**. En una investigación interna, la autorización la emiten normalmente la gerencia general y la asesoría legal de la organización; en un proceso judicial, la autoridad que corresponda. El equipo forense no amplía el alcance por iniciativa propia.

| Elemento del alcance | Pregunta que responde | Ejemplo |
|---|---|---|
| Objetivo | ¿Para qué se investiga? | Determinar si la lista de precios 2027 salió de la organización |
| Recursos incluidos | ¿Qué fuentes pueden examinarse? | Notebook corporativo, registro del servidor de correo, buzón corporativo |
| Intervalo | ¿Qué periodo se examina? | 01-09-2026 00:00 a 07-09-2026 23:59, hora de Chile (`-04:00` hasta el cambio de horario del 06-09; `-03:00` después) |
| Exclusiones | ¿Qué no se toca? | Teléfono personal, mensajes personales, otros vendedores |
| Responsable | ¿Quién dirige y responde? | Jefatura de TI |
| Escalamiento | ¿A quién se consulta si algo cambia? | Gerencia General y abogado externo |
| Criterios de término | ¿Cuándo se detiene o se da por concluido? | Preguntas respondidas o imposibilidad documentada |

## Proporcionalidad y minimización

**Proporcional** significa que la intrusión en datos y personas es acorde al objetivo. **Minimizar** significa obtener y examinar solo lo necesario. Ambas ideas protegen a las personas investigadas y también al caso: un informe que incluye datos que no debía tratar pierde credibilidad.

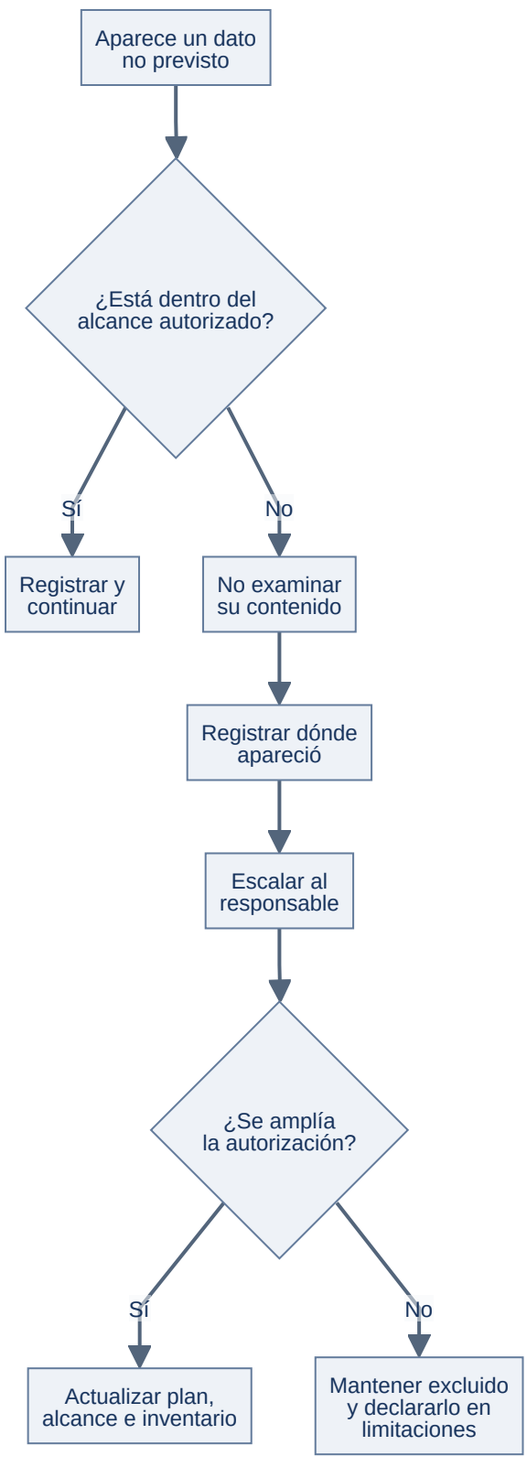
Una exportación puede traer más de lo autorizado. Por ejemplo, TI exporta todos los mensajes de un día cuando la autorización cubría solo los enviados a dominios externos. El equipo no "aprovecha" ese exceso: lo registra, filtra al alcance y no examina lo excluido.

## Criterios de término

Un plan necesita saber cuándo termina. Los criterios típicos son:

- las preguntas quedaron respondidas con las fuentes disponibles;
- se documentó que una pregunta no puede responderse con esas fuentes;
- la integridad de una fuente quedó comprometida y debe reemplazarse;
- aparece evidencia fuera de alcance y se requiere una nueva decisión;
- se agota el plazo y se emite un informe parcial con límites declarados.

## Qué hacer ante lo inesperado



El caso típico es un registro relevante fuera del intervalo: un acceso a un enlace ocurrido a la mañana siguiente. Puede ser muy importante, pero no está autorizado. Se anota que existe, se escala y se espera la decisión.

## 3. Un proceso, varias normas

Las normas y guías no se contradicen: describen el mismo recorrido con distinto nivel de detalle y desde distintos puntos de vista.

| Referencia | Qué aporta a esta lección |
|---|---|
| NIST SP 800-86 | Cuatro fases del proceso forense: **recolección**, **examen**, **análisis** y **reporte** |
| ISO/IEC 27037 | Identificación, recolección, adquisición y preservación de evidencia digital; principios de relevancia, confiabilidad y suficiencia |
| ISO/IEC 27042 | Análisis e interpretación; repetibilidad, reproducibilidad y revisión |
| NIST SP 800-61 Rev. 3 | Respuesta a incidentes integrada a la gestión de riesgos; roles, comunicación y coordinación con la investigación |
| RFC 3227 | Orden de volatilidad y principios de recolección |
| SWGDE, requisitos de redacción de informes | Contenido mínimo y claridad del informe forense |

Una forma práctica de relacionarlas:

| Etapa del caso | NIST SP 800-86 | ISO/IEC 27037 / 27042 | Producto |
|---|---|---|---|
| Preguntas, alcance y autorización | (preparación previa) | Identificación | Plan y alcance |
| Inventario y orden | Recolección | Identificación y recolección | Inventario, orden de adquisición |
| Copias y custodia | Recolección | Adquisición y preservación | Copias verificadas, cadena de custodia |
| Filtrado y extracción | Examen | Análisis | Salidas guardadas |
| Correlación e interpretación | Análisis | Interpretación | Cronología, hallazgos |
| Informe y presentación | Reporte | Reporte | Informe, anexos, defensa |

### Adquisición, examen e interpretación no se mezclan

La separación de etapas no es burocracia. Cada etapa responde a una pregunta distinta:

- **adquisición**: ¿obtuve una copia fiel? Se demuestra con hash y custodia;
- **examen**: ¿qué datos contiene? Se demuestra con el comando y su salida;
- **interpretación**: ¿qué significan esos datos para la pregunta? Se demuestra con razonamiento explícito, confianza y alternativas.

Cuando un informe dice "el usuario robó la oferta" mezcla las tres en una frase y no deja ver dónde está el salto.

## 4. Inventario e identificadores

El inventario es la lista de **todas** las fuentes identificadas, incluso las que no se adquirirán. Su función es que nadie pierda de vista qué existe, dónde está, quién la tiene y en qué estado.

| Campo | Para qué sirve |
|---|---|
| Identificador único | Citar la fuente sin ambigüedad en custodia, análisis e informe |
| Descripción | Saber qué es: tipo, modelo, cuenta, servicio |
| Custodio actual | Saber quién responde por ella ahora |
| Ubicación | Saber dónde está físicamente o en qué servicio |
| Estado | Encendido, apagado, exportado, en línea, bloqueado |
| Volatilidad o retención | Saber qué urgencia tiene |
| Hash | Comprobar integridad cuando ya existe una copia |
| Autorización | Saber si está incluida, excluida o pendiente |

### Identificadores que no se repiten

Un identificador como `EV-2` no sirve si dos fuentes lo comparten. Se recomienda un prefijo de caso (`CA-EV02`) y una regla para derivados:

| Identificador | Qué representa |
|---|---|
| `CA-EV01` | Exportación original del registro del servidor de correo |
| `CA-EV01-T1` | Primera copia de trabajo de esa exportación |
| `CA-EV01-S1` | Primera salida obtenida desde esa copia |

Así cualquier salida puede rastrearse hasta la copia, y la copia hasta el original. Un identificador asignado no se reutiliza, aunque la fuente se descarte: se marca como descartada y se explica por qué.

## 5. Orden de adquisición: volatilidad, retención y dependencia

El orden no se decide por comodidad. Se decide por lo que se pierde primero.

### Volatilidad

La RFC 3227 propone recolectar de lo más volátil a lo menos volátil:

| Orden | Fuente | Ejemplo |
|---|---|---|
| 1 | Registros y caché del procesador | Prácticamente inaccesibles en la práctica |
| 2 | Tabla de rutas, caché ARP, tabla de procesos, estadísticas del núcleo, memoria | Procesos y conexiones de un notebook encendido |
| 3 | Sistemas de archivos temporales | Archivos en `/tmp` o en memoria |
| 4 | Disco | Sistema de archivos del notebook |
| 5 | Registros remotos y datos de monitoreo | Logs de VPN, proxy o SIEM |
| 6 | Configuración física y topología de red | Diagramas, conexiones |
| 7 | Medios de archivo | Respaldos |

### Retención

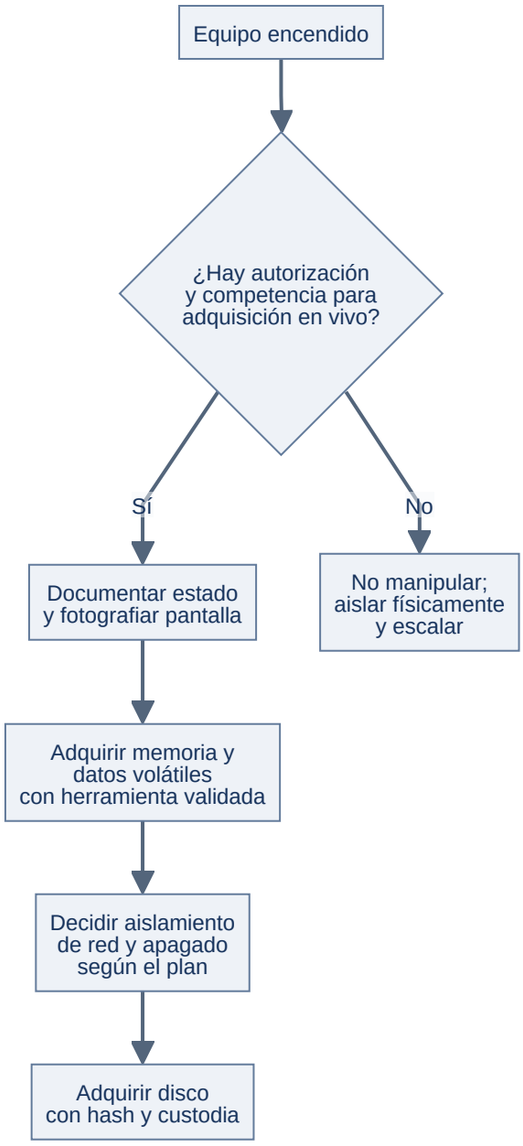
En cloud y servicios gestionados el riesgo no es solo la volatilidad física: los registros **expiran** según el plan contratado. Una auditoría que se conserva siete días puede ser más urgente que un disco apagado que no cambiará. Por eso el orden real combina ambas cosas.

### Dependencia

Algunas fuentes solo se interpretan con otras. La IP asignada por la VPN solo identifica un equipo si existe el registro de asignación; un enlace compartido solo se relaciona con un objeto si la auditoría registra ambos identificadores. Si una fuente depende de otra que expira, ambas suben de prioridad.

### El notebook encendido

"Apáguenlo para que no borre nada" es una decisión que destruye memoria, conexiones activas, procesos y, si el disco está cifrado, puede dejar el contenido inaccesible sin la clave. Tampoco es correcto dejarlo indefinidamente encendido y conectado. La decisión se toma con criterio técnico y autorización:




En esta asignatura no se adquiere memoria de equipos reales; lo importante es saber que la decisión existe, quién la toma y qué se pierde con cada opción.

## 6. Cadena de custodia

La cadena de custodia es el registro que demuestra, para cada evidencia, **quién la tuvo, cuándo, para qué y en qué estado**, desde que se identifica hasta que se presenta o se devuelve. Si un tramo no puede demostrarse, la evidencia no se vuelve falsa, pero su valor disminuye y alguien podrá preguntar qué pasó en ese hueco.

### Campos mínimos de una transferencia

| Campo | Por qué es necesario |
|---|---|
| Fecha y hora con zona | Ordenar transferencias y compararlas con otros registros |
| Identificador de la evidencia | Saber exactamente qué se transfirió |
| Hash completo y algoritmo | Demostrar que el contenido no cambió entre manos |
| Entrega | Saber quién respondía antes |
| Recibe | Saber quién responde después |
| Propósito | Justificar por qué se movió: preservación, examen, análisis, revisión |
| Estado | Describir cómo estaba: encendido, sellado, copia sin escritura |
| Firma o control equivalente | Demostrar que ambas partes reconocen la transferencia |

### Errores típicos

| Error | Riesgo |
|---|---|
| Fecha sin hora o sin zona | No se puede ordenar respecto de otros eventos |
| Campo "entrega" vacío | Hay un tramo sin responsable |

| Error | Riesgo |
|---|---|
| Hash parcial ( `3f9a1c07...` ) | Un prefijo no demuestra igualdad completa del contenido |
| "Copia entregada" sin identificador | No se sabe qué copia es ni de qué original proviene |
| Identificador repetido en el inventario | La fila puede referirse a dos fuentes distintas |
| Propósito vacío | No se justifica el acceso a la evidencia |

### Corregir sin inventar

Cuando un registro recibido está incompleto, la corrección **no** consiste en completar el dato que parece lógico. Se escribe **por confirmar**, se identifica quién puede confirmarlo y, si el dato no puede establecerse, se declara como limitación. Inventar una hora o un responsable convierte un problema de trazabilidad en un problema de veracidad.

Del mismo modo, un registro propio que tiene un error no se borra: se agrega una fila nueva que lo corrige y se explica. La cadena de custodia crece por adición.

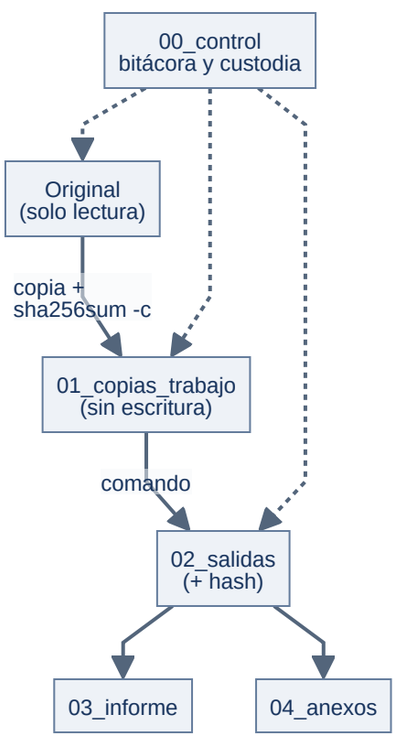
### Custodia de evidencia digital

En evidencia digital, la custodia física (el disco, el pendrive) y la custodia lógica (el archivo) conviven:

- el **manifiesto** de hashes acompaña a la entrega y se verifica al recibir;
- cada copia de trabajo se verifica contra ese manifiesto antes de usarse;
- el hash de cada transferencia se calcula en el momento, no se copia del registro anterior;
- las salidas del análisis también se registran con hash, porque serán anexos.

## 7. Almacenamiento y control de acceso

La estructura de almacenamiento hace visible la separación entre original, copia, resultado e informe.




| Control | Propósito |
|---|---|
| Original en solo lectura | Evitar alteraciones accidentales |
| Copias de trabajo verificadas y sin escritura | Analizar sin arriesgar el original |
| Salidas separadas y con hash | Poder anexarlas y demostrar que no cambiaron |
| Acceso por rol | Solo quien trabaja en el caso accede |
| Almacenamiento cifrado y respaldo | Proteger confidencialidad y disponibilidad |
| Bitácora y custodia en una carpeta de control | Documentar el método junto con los datos |

## 8. Plan de análisis: la matriz pregunta-fuente-técnica

La matriz es el centro del plan. Obliga a decir, **antes** de analizar, qué fuente responde cada pregunta, con qué técnica, qué se espera encontrar y qué no podrá decirse.

| Pregunta | Fuente | Técnica | Resultado esperado | Limitación |
|---|---|---|---|---|
| P1: ¿se envió el archivo de precios a dominios externos? | Registro del servidor de correo (`CA-EV01`) | Filtrar por cuenta, intervalo y nombre de adjunto; convertir a UTC | Mensajes enviados con destinatario y nombre de adjunto | Registra nombres, no contenido |
| P1: ¿el adjunto es la lista interna? | Buzón corporativo (`CA-EV03`) y archivo interno | Extraer el adjunto conservado y comparar SHA-256 | Igualdad o diferencia de bytes | Igualdad de hash no indica quién lo envió |
| P2: ¿hubo acceso al archivo desde el equipo? | Notebook `CA-NB-04` (`CA-EV02`) | Línea de tiempo del sistema de archivos y archivos recientes | Accesos o aperturas del archivo en el intervalo | Las marcas de tiempo pueden alterarse; no identifica a la persona |

Una buena matriz también muestra **qué no se hará**. Si ninguna pregunta necesita el respaldo del sistema de ventas, ese respaldo no se examina aunque esté disponible.

## 9. Cronología integrada

La cronología integra los eventos de todas las fuentes en un solo eje temporal. Las reglas ya se trabajaron en lecciones anteriores y aquí se aplican juntas:

1. convertir todas las horas a UTC una sola vez, usando el desfase que declara la fuente o su ficha técnica;
2. citar cada evento con archivo y línea, o tabla y fila;
3. registrar la hora original junto a la UTC para que la conversión pueda revisarse;
4. distinguir uniones **directas** (mismo identificador), **por valor** (misma IP o hash) y **temporales** (solo cercanía);
5. no rellenar huecos con suposiciones.

| Hora original | Fuente | Hora UTC | Evento |
|---|---|---|---|
| `2026-09-04 11:01:40` (local `-04:00`) | Notebook, línea de tiempo L88 | 15:01:40 | Apertura de `precios-2027.xlsx` |
| `2026-09-04T15:02:11Z` | Servidor de correo L212 | 15:02:11 | Mensaje enviado con adjunto |
| `2026-09-04T11:02:13-04:00` | Buzón, metadatos L9 | 15:02:13 | Mensaje en carpeta Enviados |

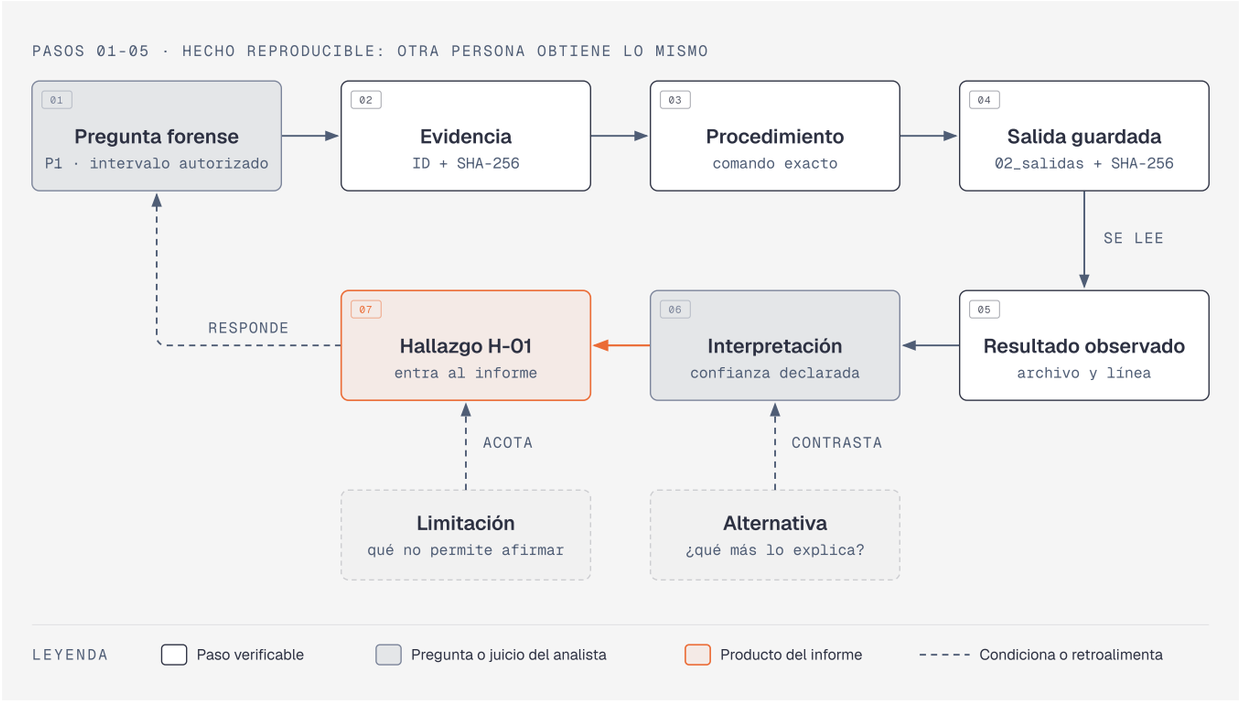
Una fuente que **no escribe** su desfase (como una línea de tiempo exportada en "hora local") depende de la ficha técnica. Esa dependencia se anota: si la ficha estuviera equivocada, toda la fuente se desplazaría.

## 10. Del dato al hallazgo reproducible

ISO/IEC 27042 distingue dos propiedades:

- **repetibilidad**: la misma persona, con el mismo método y las mismas condiciones, obtiene el mismo resultado;
- **reproducibilidad**: otra persona, con el mismo método sobre la misma evidencia, aunque con otro equipo, obtiene el mismo resultado.

Un informe forense aspira a la reproducibilidad. Para lograrla, cada hallazgo debe contener lo que otra persona necesita para llegar al mismo punto:




| Campo | Contenido | Ejemplo |
|---|---|---|
| Identificador | Código único del hallazgo | H-01 |
| Pregunta | Qué pregunta forense responde | P1 |
| Evidencia | Identificador y SHA-256 | `CA-EV01`, SHA-256 completo en el informe |
| Procedimiento | Comando exacto, herramienta y versión | `grep -n 'precios-2027' registro-correo.log` |
| Salida | Archivo guardado y su hash | `02_salidas/correo-precios.txt` y su SHA-256 |
| Resultado observado | Qué dicen los datos, sin adjetivos | La cuenta `v.mella` envió un adjunto `precios-2027.xlsx` a `ventas@distribuidor.invalid` a las 15:02:11Z |
| Interpretación | Qué significa para la pregunta | Un archivo con ese nombre salió hacia un dominio externo |
| Confianza | Alta, media o baja, con razón | Media: una fuente; el contenido no se comparó por hash |
| Alternativa | Otra explicación compatible con los datos | Archivo homónimo con otro contenido, o credencial usada por otra persona |
| Limitación | Qué no permite afirmar | No identifica a la persona ni el contenido del adjunto |

## Niveles de confianza

En este curso se usa una escala simple, siempre justificada:

| Nivel | Cuándo usarlo |
|---|---|
| **Alta** | Varias fuentes independientes coinciden mediante uniones directas o por valor, con integridad verificada y sin explicación alternativa razonable |
| **Media** | Una fuente registra la acción y otra la corrobora parcialmente, o existe una alternativa razonable no descartada |
| **Baja** | Solo cercanía temporal, una fuente única sin corroboración o integridad no verificable |

## Lenguaje del hallazgo

| Sobreafirmación | Redacción acotada |
|---|---|
| "La vendedora filtró los precios." | "La cuenta `v.mella` envió un adjunto llamado `precios-2027.xlsx` a un dominio externo." |
| "El adjunto era la lista de precios." | "El adjunto tiene ese nombre; su contenido no fue comparado con la versión interna." |
| "El distribuidor usó los precios." | "El registro muestra la entrega al servidor de destino; no muestra qué hizo el destinatario." |
| "Queda demostrado." | "Los registros son consistentes con...; confianza media porque..." |

## 11. Arquitectura del informe forense

El informe es el producto que leerán personas distintas con necesidades distintas. Su estructura debe permitir que cada lector encuentre lo suyo y que un revisor técnico pueda rastrear cada hallazgo hasta la evidencia.

| # | Sección | Contenido | Lector principal |
|---|---|---|---|
| 1 | Identificación del caso | Código, solicitante, autorización, equipo, fechas, versión del informe | Todos |
| 2 | Resumen ejecutivo | Qué se preguntó, qué se encontró, qué no se puede afirmar y qué decisión se necesita | Gerencia |
| 3 | Alcance y preguntas | Objetivo, recursos, intervalo, exclusiones y preguntas forenses | Legal y gerencia |
| 4 | Evidencia y custodia | Inventario, hashes, estado y resumen de la cadena de custodia | Revisor técnico y legal |
| 5 | Metodología y herramientas | Procedimientos, versiones, conversiones horarias y controles de integridad | Revisor técnico |
| 6 | Cronología | Eventos normalizados en UTC con fuente y línea | Todos |
| 7 | Hallazgos | Hallazgos reproducibles con confianza, alternativa y limitación | Revisor técnico |
| 8 | Limitaciones | Fuentes no disponibles, exclusiones, retención, atribución | Todos |
| 9 | Conclusiones | Respuesta a cada pregunta forense, sin ir más allá de los hallazgos | Gerencia y legal |
| 10 | Recomendaciones | Preservaciones pendientes, ampliaciones a decidir, contención | Gerencia |
| A | Anexos | Manifiestos, comandos, salidas con hash, custodia completa, glosario | Revisor técnico |

### El resumen ejecutivo

Se escribe al final y se ubica al principio. Responde cuatro cosas en lenguaje claro:

1. qué se hizo;
2. qué se observó;
3. qué no puede afirmarse todavía;
4. qué decisión se necesita.

> Ejemplo para el caso CERRO AZUL (sección 13): se preservaron y verificaron el registro del servidor de correo y el notebook corporativo autorizados. En la semana revisada, la cuenta corporativa de ventas envió a un distribuidor externo un adjunto con el nombre de la lista de precios 2027. Todavía no se ha comprobado que ese adjunto sea la lista interna ni quién operaba la cuenta. Se necesita autorizar la comparación del adjunto conservado con la versión interna.

### Conclusiones que no exceden los datos

Cada conclusión responde una pregunta y cita los hallazgos que la sostienen. Si un hallazgo tiene confianza media, la conclusión no puede tener confianza alta. Si la pregunta no puede responderse, se dice así y se explica qué fuente lo permitiría.

## 12. Calidad, sesgos y revisión entre pares

Un plan bien diseñado reduce errores, pero no los elimina. Tres controles complementan el método:

- **revisión entre pares**: otra persona lee la bitácora buscando acciones fuera de alcance, fuentes sin preservar, hallazgos sin evidencia y conclusiones que exceden los datos;
- **verificación de herramientas**: registrar versión y, cuando sea posible, probar la herramienta con datos conocidos antes de usarla en evidencia;
- **hipótesis alternativas**: por cada interpretación, preguntarse qué otra explicación es compatible con los mismos datos.

El **sesgo de confirmación** aparece cuando la solicitud ya trae un sospechoso. El analista tiende a buscar lo que confirma la sospecha y a no ver lo que la contradice. Formular preguntas sobre cuentas y acciones, en lugar de sobre personas, y registrar alternativas, son las defensas prácticas.

## 13. Ejemplo resuelto - caso CERRO AZUL LTDA (ficticio)

CERRO AZUL LTDA sospecha que la lista de precios 2027 se envió a un distribuidor externo. La gerencia comercial pide "revisar el computador y el celular de la vendedora y todo su correo del último año".

### Solicitud transformada

| Problema detectado | Decisión |
|---|---|
| "Todo su correo del último año" | Desproporcionado; se propone intervalo de una semana y mensajes a dominios externos |
| "El celular de la vendedora" | Es personal; se excluye y se escala |
| Sospecha nominal | Las preguntas se formulan sobre la cuenta `v.mella` y el equipo `CA-NB-04` |

Preguntas forenses:

1. ¿Se envió, desde la cuenta corporativa `v.mella`, la lista de precios 2027 a dominios externos entre el 01-09 y el 07-09?
2. ¿Qué registros del equipo `CA-NB-04` muestran acceso al archivo en ese intervalo?

### Plan resumido

| Orden | Fuente | Motivo | Acción |
|---|---|---|---|
| 1 | Registro de mensajes del servidor de correo | Retención de 14 días | Exportar enviados a dominios externos, con hash |
| 2 | Notebook `CA-NB-04`, apagado | Estable, pero puede reasignarse | Adquirir disco con bloqueador, hash y custodia |
| 3 | Buzón corporativo | Conservado 1 año | Exportar mensajes del intervalo a dominios externos |

### Custodia: una fila corregida

| Recibido | Corrección |
|---|---|
| `03-09, EV-2, Analista B, "copia"` | `03-09-2026 hora por confirmar (-04:00); CA-EV02-T1 copia de trabajo de CA-EV02; SHA-256 completo por calcular; entrega por confirmar; recibe Analista B; propósito examen; estado sin escritura` |

### Hallazgo

| Campo | Contenido |
|---|---|
| H-01 | El registro del servidor de correo ( `CA-EV01`, línea 212) muestra un mensaje enviado por `v.mella` el 04-09-2026 a las 15:02:11Z a `ventas@distribuidor.invalid` con adjunto `precios-2027.xlsx` |
| Procedimiento | `grep -n 'precios-2027' registro-correo.log`, salida `S1` con hash anotado |
| Interpretación | La cuenta envió un adjunto con ese nombre a un dominio externo |
| Confianza | Media: una fuente; el adjunto no se ha comparado por hash con el archivo interno |
| Alternativa | El adjunto puede tener ese nombre pero otro contenido |
| Limitación | No identifica a la persona que operaba la cuenta; no demuestra el contenido del adjunto |

### Conclusión de la etapa

> Los registros autorizados muestran que la cuenta corporativa `v.mella` envió a un dominio externo un adjunto llamado `precios-2027.xlsx`. No se ha verificado que su contenido sea la lista de precios interna ni quién operaba la cuenta. Se recomienda comparar por hash el adjunto conservado en el buzón con la versión interna.

## 14. Errores frecuentes

- Comenzar a "mirar los logs" antes de tener preguntas y alcance.
- Aceptar el sospechoso de la solicitud como hipótesis única.
- Examinar fuentes personales o de terceros porque "estaban disponibles".
- Apagar o encender equipos sin evaluar qué se pierde.
- Repetir identificadores o reutilizar uno descartado.
- Completar la cadena de custodia con datos supuestos.
- Copiar un hash del registro anterior en vez de calcularlo.
- Trabajar sobre el original en lugar de una copia verificada.
- Redactar hallazgos sin guardar la salida que los respalda.

- Escribir conclusiones con más confianza que los hallazgos que las sostienen.
- Usar un resumen ejecutivo lleno de tecnicismos o, al revés, sin límites.

## 15. Preparación para la actividad

Antes de la clase:

1. Relean la solicitud del caso `NS-CASO05` que aparece en la actividad y marquen frases ambiguas.
2. Escriban una pregunta forense que no mencione a ninguna persona.
3. Repasen la conversión de hora local a UTC con `date -u -d`.
4. Recuerden la diferencia entre unión directa, por valor y temporal.
5. Lean la tabla de campos mínimos de custodia y la de campos de un hallazgo.

Durante la actividad, la autorización del caso es el límite: si algo no está autorizado, se anota y se escala.

## 16. Glosario

| Término | Definición |
|---|---|
| Alcance | Conjunto de fuentes, intervalo y objetivos que la autorización permite examinar |
| Autorización | Decisión formal de quien tiene autoridad para permitir la investigación |
| Cadena de custodia | Registro continuo de quién tuvo una evidencia, cuándo, para qué y en qué estado |
| Copia de trabajo | Copia verificada del original sobre la que se analiza |
| Criterio de término | Condición que indica cuándo se detiene o concluye el trabajo |
| Escalamiento | Elevar una decisión a quien tiene autoridad para tomarla |
| Exclusión | Fuente o dato que la autorización deja fuera |
| Hallazgo | Resultado observado e interpretado, con evidencia, procedimiento, confianza y limitación |
| Inventario | Lista de todas las fuentes identificadas, con su estado y custodio |
| Manifiesto | Archivo que lista los hashes de un conjunto de archivos |
| Minimización | Obtener y examinar solo los datos necesarios para el objetivo |
| Orden de volatilidad | Prioridad de recolección según qué se pierde primero |
| Pregunta forense | Pregunta acotada que puede responderse con evidencia sin presuponer el resultado |
| Proporcionalidad | Relación adecuada entre la intrusión y el objetivo de la investigación |
| Repetibilidad | Mismo resultado con el mismo método, persona y condiciones |
| Reproducibilidad | Mismo resultado con el mismo método por otra persona o en otro equipo |
| Resumen ejecutivo | Síntesis del informe para quien decide, sin tecnicismos innecesarios |
| Retención | Tiempo que un servicio conserva sus registros antes de eliminarlos |
| Sesgo de confirmación | Tendencia a buscar solo lo que confirma una idea previa |

## Fuentes


- NIST SP 800-86 - Guide to Integrating Forensic Techniques into Incident Response. Fases de recolección, examen, análisis y reporte.
- NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cybersecurity Risk Management. Roles, comunicación y respuesta a incidentes integrada a la gestión de riesgos.
- ISO/IEC 27037:2012 - Guidelines for identification, collection, acquisition and preservation of digital evidence. Identificación, recolección, adquisición y preservación; relevancia, confiabilidad y suficiencia.
- ISO/IEC 27042:2015 - Guidelines for the analysis and interpretation of digital evidence. Análisis, interpretación, repetibilidad, reproducibilidad y revisión.
- RFC 3227 - Guidelines for Evidence Collection and Archiving. Orden de volatilidad y principios de recolección.
- SWGDE 18-Q-002 - Requirements for Report Writing in Digital and Multimedia Forensics. Contenido y claridad del informe forense.
- SWGDE 18-F-002 - Best Practices for Digital Evidence Collection. Inventario, estado de dispositivos, integridad y documentación.
- NIST - Digital Evidence. Recursos del programa de evidencia digital.